

# Y-Dude

IBB-ProFIT-taugliche Unternehmens- und Technologieanalyse  
Production-Stand vom 30. August 2026

Stand: 2026-08-30 · Umgebung: PRODUCTION (<https://y-dude.com>)

Art des Dokuments: **reine Analyse und Dokumentation**. Im Rahmen dieser Analyse

wurden keine Änderungen an Code, Datenbank, RLS, Auth, Storage, Stripe,

Subscriptions, CDN, Serverkonfiguration oder Produktionsdaten vorgenommen.

Es wurden ausschließlich Leseoperationen ausgeführt (HTTP-Kopfzeilenprüfung,

Quellcode- und Dokumentenauswertung, lokale Testsuite).

Statusklassen, die in diesem Bericht strikt getrennt werden:

**PRODUCTION AKTIV · LAUNCHPAD/STAGING · BEWUSST ZURÜCKGESTELLT ·**

**NICHT IMPLEMENTIERT · NICHT MESSBAR.**

## 1. Executive Summary

Y-Dude ist eine eigenentwickelte, audio-zentrierte Social- und

Marktplatz-Plattform (SlangTag = Audio-Pendant zum Hashtag) mit

Berlin-basierter Entwicklung. Der Production-Stand vom 2026-08-30 ist

funktional vollständig lauffähig, sicherheitsgehärtet und unter synthetischer

Last bis 750 gleichzeitigen Nutzern gemessen.

Nachweisbare Kernkennzahlen (Quellen in Abschnitt 20):

| RLS-Policies (Schema public)                            | 285                                  | Release-Checkpoint 2026-08-29             |
|---------------------------------------------------------|--------------------------------------|-------------------------------------------|
| Tabellen mit aktivierter Zeilensicherheit               | 116                                  | Release-Checkpoint 2026-08-29             |
| Indexe (Schema public)                                  | 325 (+2 durch Migration 10)          | Release-Checkpoint 2026-08-29             |
| Ungekapselte auth.uid()-Policies                        | 0                                    | Release-Checkpoint 2026-08-29             |
| Gekapselte has_role()-Aufrufe                           | 71 (+23 bewusst unverändert)         | Release-Checkpoint 2026-08-29             |
| Unit-/Logiktests                                        | 480 (21 Dateien), grün am 2026-08-30 | lokaler Lauf <code>bun run test</code>    |
| DB-Integrationstests (nur lesend)                       | 26 (2 Dateien)                       | <code>bun run verify</code> 2026-08-29/30 |
| E2E-Browsertests                                        | 10 bestanden, 1 übersprungen         | <code>bun run verify</code>               |
| Load-Test Requests gesamt                               | 94.720                               | Lasttest-Rohdaten 2026-08-30              |
| Serverfehler (5xx) / HTTP-4xx                           | 0 / 0                                | Lasttest-Rohdaten                         |
| Timeouts                                                | 1 (von 94.720 = 0,001 %)             | Lasttest-Rohdaten                         |
| Spitzendurchsatz                                        | 366,38 RPS bei 750 VUs               | Lasttest-Rohdaten                         |
| p95 / p99 bei 750 VUs                                   | 45 ms / 114 ms                       | Lasttest-Rohdaten                         |
| SSR-Cache-HIT-Rate öffentliche Beitragsseiten (750 VUs) | 8.340/9.084 = 91,8 %                 | Lasttest-Rohdaten                         |
| Quellcode-Umfang (src/)                                 | 486 Dateien, 101.730 Zeilen TS/TSX   | Repository-Zählung 2026-08-30             |

Einordnung: Der Innovations- und Eigenleistungsanteil liegt schwerpunktmäßig in

der serverseitig durchgesetzten Zugriffskontrolle (RLS-Architektur mit

Sicherheitsfunktionen statt Client-Filterung), der eigenen Audio-Objekt-Logik

(SlangTag mit Platzierung, Skalierung, Rotation, Trimming, Voting, Globe) sowie in den 2026-08-29/30 umgesetzten Performance-Mechaniken (SSR-Kurzzeitcache mit Sicherheitsgate, Request-Batching). Standarddienste (Supabase/Postgres, Stripe, Cloudflare-Edge, TanStack Start, Tailwind) werden verwendet, aber nicht als Eigenleistung ausgewiesen.

Gesamtbewertung des Analysestands: ■ **IBB-ProFIT PRODUCTION ANALYSE ERSTELLT**  
(mit dokumentierten Messgrenzen in Abschnitt 11 und 16).

## 2. Unternehmens- und Produktbeschreibung

Y-Dude ist eine Progressive Web App (PWA) mit folgenden Produktbausteinen – alle **PRODUCTION AKTIV**:

- **SlangTag**: 1–5-Sekunden-Audioaufnahme, verankert auf Bild/GIF, frei platzierbar, skalierbar und rotierbar; Typenmodell Community (\$, grün), Creator/Business (\$\$, blau) und Hashtag (#, rot).
  - **Feed** mit Tabs (lokal, global, trending, „folge ich“), Diversity-Layer, Keyset-Pagination, AutoPlay-Steuerung, Likes, Kommentare, Beitrags-Bearbeitung für Autoren.
  - **SlangTag Arena**: Community-Voting und Challenge-Strukturen.
  - **Slang Globe**: 3D-Weltkugel (Three.js) mit Heatmap, Inertia-Steuerung und Level-of-Detail-System.
  - **Messenger**: getrennte Bereiche Connections und Market, Übersetzung, gebündelte Push-Benachrichtigungen, Lesestatus.
  - **Y-Dude Market**: Artikel, Transaktionslogik, Checkout, Verkäuferprofile, Gebührenmodell; Zahlungsanbindung über Stripe.
  - **Werbe-/Ad-Kernel**: Adapter-Architektur mit TCF-v2.2-Gating; Google AdSense integriert, aber **BEWUSST ZURÜCKGESTELLT** (nicht live geschaltet).
  - **Admin-Cockpit**: Moderation, KI-Moderation, Reports, Appeals, Health, Alerting, Transparenzberichte, DSA-/DSGVO-Werkzeuge.
- Rechtsdokumente (AGB, Datenschutz, Richtlinien, Impressum, Transparenz) sind als öffentliche Routen produktiv ausgeliefert.

## 3. Ausgangslage (Stand vor den letzten zwei Tagen)

Vor dem 2026-08-29 war die Plattform funktional vollständig, jedoch mit drei bekannten Schwächen:

1. **Policy-Effizienz**: `auth.uid()`- und `has_role()`-Aufrufe waren in RLS-Policies teilweise ungekapselt, was pro Zeile ausgewertet wird (InitPlan-Problematik).
2. **Fehlende Lastnachweise** auf dem aktuellen Production-Stand.

3. **Wiederholte Serverarbeit** bei öffentlichen Seiten und bei häufigen Kleinstanfragen (View-Zähler, Übersetzungen).

Diese drei Punkte wurden in den Releases vom 2026-08-29 und 2026-08-30 bearbeitet.

## 4. Entwicklungsstand

| Kernsoziales (Feed, SlangTag, Arena, Globe, Profile) | PRODUCTION AKTIV                   | Routenbaum <code>src/routes</code> , E2E-Tests                     |
|------------------------------------------------------|------------------------------------|--------------------------------------------------------------------|
| Messenger (Connections + Market)                     | PRODUCTION AKTIV                   | <code>E2E messenger.spec.ts</code> , Unit-Tests                    |
| Market inkl. Stripe-Checkout                         | PRODUCTION AKTIV                   | <code>market-transaction-flow.test.ts</code> , Webhook-Tests       |
| Business-Abo ( <code>/business</code> )              | PRODUCTION AKTIV                   | <code>src/routes/_authenticated/business.tsx</code> , 380 Zeilen   |
| Registrierung Privat/Business-Einstieg               | PRODUCTION AKTIV (seit 2026-08-30) | <code>docs/PRODUCTION_REGISTRATION_UX_RELEASE_2026-08-30.md</code> |
| RLS-Härtung Migrationen 1–10                         | PRODUCTION AKTIV                   | <code>docs/PROD_FINAL_RELEASE_CHECKPOINT_2026-08-29.md</code>      |
| Performance-Blöcke A–D                               | PRODUCTION AKTIV                   | <code>docs/PROD_PERFORMANCE_RELEASE_2026-08-30.md</code>           |
| <code>/assets/*</code> unveränderliches Caching      | PRODUCTION AKTIV (live geprüft)    | HTTP-Kopfzeile, Abschnitt 20                                       |
| <code>public/*</code> CDN-Caching                    | BEWUSST ZURÜCKGESTELLT             | HTTP-Kopfzeile, Abschnitt 16                                       |
| AdSense-Auslieferung                                 | BEWUSST ZURÜCKGESTELLT             | Ad-Adapter über Umgebungsvariable deaktiviert                      |
| Separate Staging-Datenbank                           | NICHT IMPLEMENTIERT                | <code>docs/STAGING_OPTIONEN_PAYMENTS_2026-08-28.md</code>          |
| Lastnachweis angemeldeter Pfade                      | NICHT MESSBAR (bisher)             | Lasttest war anonym/lesend                                         |

## 5. Technische Architektur

**Frontend/Server-Framework:** TanStack Start v1 (React 19, Vite 7), SSR und Serverfunktionen im Edge-Worker-Modell (Cloudflare). Routing dateibasiert (41 Einträge unter `src/routes`, inkl. geschütztem Teilbaum `_authenticated/` und öffentlichen API-Routen unter `routes/api/public/*`).

**Datenhaltung:** Postgres (Supabase-Plattform) mit Zeilensicherheit als primärem Schutzmechanismus; 116 Tabellen mit RLS, 285 Policies, 325 Indexe.

**Zugriffssteuerung:** Rollen in eigener Tabelle `user_roles`, Auswertung über `SECURITY DEFINER`-Funktion `has_role(uuid, app_role)` mit festem `search_path`; Sichtbarkeitslogik in gekapselten Hilfsfunktionen (`can_view_post`, `test_user_visible`, `are_connected`, `is_following`). Diese Funktionen geben ausschließlich Boolesche Werte zurück und leiten Identität allein aus `auth.uid()` ab – nicht aus Requestdaten.

**Medien:** privater Bucket, Auslieferung nur über signierte URLs (7 Tage), Cache-Klassen beim Upload; unverpixelte Originale no-store und nie geräteweit gespeichert.

**Caching-Schichten (PRODUCTION AKTIV):**

1. `/assets/*`: `public`, `max-age=31536000`, `immutable` (live verifiziert).
2. SSR-Kurzzeitcache in der Serverinstanz für nicht personalisierte Seiten (`/`, `/auth`, `/agb`, `/datenschutz`, `/impressum`, `/richtlinien`, `/reset-password`) und für `/post/<uuid>` (TTL 60 s), mit hartem Sicherheitsgate: nur GET/HEAD, Status 200, **kein** Cookie, **keine** Authorization-Kopfzeile, kein `set-cookie`, `Vary: Cookie, Authorization`, maximal 200 Einträge, Marker-Gate `x-ydude-public-post`.
3. React-Query-Defaults (`staleTime 30 s`, `gcTime 5 min`, kein Refetch bei Fokuswechsel, `retry: 1`) und `defaultPreloadStaleTime 30 s` im Router.

**Beobachtbarkeit:** `ops_incidents`, Health-Dashboard, Heartbeat, externer Alarmkanal über `OPS_ALERT_WEBHOOK_URL` (Discord-Webhook).

## 6. Innovationsmerkmale

1. **SlangTag als Datentyp:** Audio-Objekt mit räumlicher Verankerung (Position, Skalierung, Rotation) auf Bildmedien, mit eigener Detailseite (Region, Bedeutung, Beispielsätze), Owner-Scoping (persönliche Varianten statt globaler Tags) und Moderationszustand.
2. **Serverseitig erzwungene Sichtbarkeitssemantik:** Beitragssichtbarkeit (`public / connections / following / privat`) wird nicht im Client gefiltert, sondern in Policies mit gekapselten Funktionen ausgewertet.
3. **Slang Globe:** eigene Physik (Inertia, Pinch-Zoom) und LOD-Stufen über Geodaten-Aggregation.
4. **Feed-Algorithmus mit Diversity-Layer:** Ranking plus bewusste Streuung, um Monokultur einzelner Autoren/Regionen zu verhindern.
5. **Sicherheitsgekoppelter SSR-Cache:** ein Kurzzeitcache, der eine Marker-Kopfzeile des Loaders voraussetzt und jede Anfrage mit Sitzung bedingungslos ausschließt – Cache-Design als Sicherheitsproblem behandelt.
6. **Batch-Mechaniken:** View-Zählung (700-ms-Sammelfenster, Einzel-Fallback) und Übersetzungen (`translatePostsBatch`, 120 ms / max. 20 IDs) reduzieren Requestanzahl ohne Funktionsverlust.
7. **Mehrsprachigkeit mit Geo-Lokalisierung** der öffentlichen Landingpage (`DE/AT/CH` → Deutsch, `GR/CY` → Griechisch, sonst Englisch) über Edge-Header.

## 7. Technische Eigenleistung (Abgrenzung)

**Selbst entwickelte Produkt- und Systemlogik**

- RLS-Architektur: 285 Policies, Rollenmodell in eigener Tabelle, Sicherheitsfunktionen mit festem Suchpfad, Deny-Policies für sensible

Tabellen (z. B. `newsletter_subscribers` mit 4 expliziten Deny-Policies).

- Migrationsprogramm 1–10 (InitPlan-Kapselung, `has_role`-Kapselung Blöcke A–D, zwei Indexblöcke) inkl. Vorher/Nachher-Verifikation.
- SSR-Kurzzeitcache inkl. Sicherheitsgate und Metriken (`src/lib/http-cache.server.ts`).
- Batch-Verarbeitung für Views und Übersetzungen.
- SlangTag-Editor (Canvas mit Drag/Scale/Rotate), Audio-Trimming auf 5 s, Sprachfilter/Voice-Preservation.
- Feed-Ranking und Diversity-Layer, Keyset-Pagination, Scroll-Restore.
- Messenger inkl. Push-Bündelung mit Cooldown und Deep-Links.
- Market-Transaktionsmaschine (Angebot → Transaktion → Checkout → Status), Webhook-Idempotenz und Signaturprüfung.
- Moderations- und DSA-/DSGVO-Werkzeuge: KI-Moderation, Appeals, Transparenzberichte, Datenexport, Kontolöschung, Audit-Log.
- Test- und Betriebsinfrastruktur: 480 Unit-Tests, 26 lesende DB-Integrationstests mit eigener Schutzschicht (`psql`-Zugang, der nur `select/with` zulässt), 10 E2E-Tests mit Produktionsadressen-Sperre, `scripts/verify.sh` als Freigabegate.

#### Verwendete Standarddienste/Frameworks (keine Eigenleistung)

TanStack Start/Router/Query, React 19, Vite 7, Tailwind v4, Three.js, Supabase (Postgres, Auth, Storage, Realtime), Stripe, Cloudflare-Edge, Cloudflare Turnstile, Playwright, Vitest, Remotion (Marketingvideos).

## 8. IT-Sicherheit

### Aktueller, nachgewiesener Stand

- 116 Tabellen mit aktivierter Zeilensicherheit; 285 Policies.
- 0 ungekapselte `auth.uid()`-Policies (Migrationen 1–4).
- 71 gekapselte `has_role()`-Aufrufe; 23 bewusst unveränderte Aufrufe (dokumentierte Ausnahmen, Blöcke A–D).
- Security-Linter-Baseline: 57 Findings in 4 Typen, unverändert gegenüber der Release-Baseline; **keine neuen Findings** durch Migration 9/10 – bewusst akzeptierte Baseline.
- RLS-Audit vom 2026-08-29 (read-only) mit Kategorisierung A–D: `posts` **B**, `slang_tags` **B**, `channel_categories` **B**, `comments` **C** (breiter als nötig, kein Datenleck). Gate-Ergebnis: ■ GRÜN, keine Kategorie A oder D.
- Anon-Zugriffsnachweise: `GET /rest/v1/posts` und `/rest/v1/slang_tags` als Gast → 42501 permission denied; `profiles` → 42501; `connections` → []; `messages` → []. Kommentare sind für Gäste nur zu öffentlichen, nicht ausgeblendeten Beiträgen lesbar (`can_view_post`-Filterung).

- `can_view_post`: STABLE SECURITY DEFINER, `search_path=public`, Ausführungsrecht für `anon/authenticated/service_role` gesetzt; der frühere Produktionsfehler „`permission denied for function can_view_post`“ ist für echtes `anon` nicht mehr reproduzierbar (Root-Cause-Audit 2026-08-30).
- Transportsicherheit: HSTS aktiv (`max-age=31536000`; `includeSubDomains`, live geprüft).
- Registrierung mit Cloudflare Turnstile und serverseitiger Verifikation.
- Realtime-Kanäle scoped (Vermeidung von Metadaten-Leaks).

**Bewusst akzeptierte Findings** (dokumentiert, keine Änderung):

`comments`-Leserecht für `anon` (Kategorie C), pauschale Plattform-Schreibrechte für `anon` auf `channel_categories`, die durch fehlende Policy praktisch blockiert sind (`new row violates row-level security policy`).

## 9. Skalierbarkeit

Belege statt Behauptung:

- Durchsatz stieg linear mit der Last: 24,18 → 47,54 → 118,39 → 234,95 → 366,38 RPS bei 50/100/250/500/750 VUs.
  - Die Latenz stieg dabei **nicht** an, sondern sank leicht:  
p95 66 ms (50 VUs) → 45 ms (750 VUs); p99 150 ms → 114 ms. Ursache ist die steigende Cache-Wirksamkeit bei höherer Wiederholrate.
  - Fehlerquote über alle Stufen: 0 Serverfehler, 0 HTTP-4xx, 1 Timeout bei 94.720 Requests.
  - Datenbankseitig: 325 Indexe, davon 7 gezielt im Release 2026-08-29 ergänzt (5 Indexe Block 1, 2 Indexe Block 2 auf `slang_tag_votes.user_id` und `globe_entries.round_id`).
  - Requestreduktion durch Batching (View-Batch, Übersetzungs-Batch) und durch React-Query-Defaults (kein Refetch bei Fokuswechsel, 30 s Staleness).
- Grenzen: Die Messung deckt anonyme, lesende Pfade ab. Angemeldete Pfade (Feed-Personalisierung, Messenger, Market-Schreibpfade, Medien-Uploads) sind **NICHT MESSBAR** im vorliegenden Lasttest.

## 10. Performance (Production-Release-Blöcke A–D, 2026-08-30)

| A | React-Query-Defaults + Preload-Stale-Time 30 s                                   | <code>src/router.tsx</code>                                                               | angewendet, verify grün |
|---|----------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------|-------------------------|
| B | SSR-Cache <code>/post/\$postId</code> , TTL 60 s, Marker-Gate, max. 200 Einträge | <code>src/lib/http-cache.server.ts</code> , <code>src/lib/public-post.functions.ts</code> | angewendet, verify grün |
| C | View-Batch (700 ms Sammelfenster, Einzel-Fallback)                               | <code>src/lib/data.tsx</code>                                                             | angewendet, verify grün |

| D | Translation-Batch<br>(translatePostsBatch, 120<br>ms / max. 20 IDs) | src/lib/translate.functions.ts, src/lib/use-post-translation.ts | angewendet, verify grün |
|---|---------------------------------------------------------------------|-----------------------------------------------------------------|-------------------------|

Dokumentierte Abweichungen im Release: eine rein formatierende  
Prettier-Korrektur in src/lib/data.tsx sowie eine Sicherheitsnachbesserung,  
die den internen Marker x-ydude-public-post auf **allen** Pfaden aus der  
Antwort entfernt (vorher bei Anfragen mit Cookie/Authorization noch enthalten).  
Verifikation im Release: Erstaufruf x-ydude-cache: miss, Folgeaufruf hit,  
cache-control: public, max-age=0, s-maxage=60, stale-while-revalidate=60,  
vary: Cookie, Authorization; Anfragen mit Cookie/Authorization ohne Cache und  
ohne Marker; nicht öffentliche IDs erzeugen keinen Cacheeintrag.  
Messgrenze am 2026-08-30 (live nachgeprüft): Für HTML-Antworten der öffentlichen  
Seiten liefert die Produktionsauslieferung an der Edge  
cache-control: no-cache, must-revalidate, max-age=0 zurück; die Kopfzeilen  
vary: Cookie, Authorization und x-ydude-cache sind vorhanden, beobachtet  
wurde bei Einzelabrufen miss. Der SSR-Cache ist instanzgebunden und wirkt  
daher nur bei wiederholten Anfragen auf dieselbe Instanz – genau dieses  
Verhalten zeigt die Lastmessung mit 91,8 % HIT-Rate.

## 11. Load-Test (Production, 2026-08-30)

Modus: nur lesend, anonym, synthetische Nutzer gegen https://y-dude.com.  
Geprüfte Gruppen: Landing, Asset (CDN), Auth-Seite, Auth-API, Feed (Arena),  
Market, Globe, öffentliche Beitragsseite (SSR), Kommentare (RLS), Rechtsseiten.

| 50  | 103,0 | 2.490  | 24,18  | 33 | 66 | 150 | 470    | 0 | 0 | 0 | 345/437<br>= 78,9 %     |
|-----|-------|--------|--------|----|----|-----|--------|---|---|---|-------------------------|
| 100 | 104,1 | 4.948  | 47,54  | 35 | 51 | 134 | 761    | 0 | 0 | 0 | 748/858<br>= 87,2 %     |
| 250 | 105,0 | 12.432 | 118,39 | 34 | 53 | 139 | 690    | 0 | 0 | 0 | 1.881/2.172<br>= 86,6 % |
| 500 | 106,0 | 24.898 | 234,95 | 32 | 45 | 118 | 1.109  | 0 | 0 | 0 | 3.937/4.361<br>= 90,3 % |
| 750 | 136,3 | 49.952 | 366,38 | 32 | 45 | 114 | 15.001 | 0 | 0 | 1 | 8.340/9.084<br>= 91,8 % |

Summe: **94.720 Requests**, 94.719 erfolgreich, **0 Serverfehler**,  
**0 HTTP-4xx**, **1 Timeout** (15.001 ms, Gruppe öffentliche Beitragsseite).  
Statuscodes ausschließlich 200 und 307 (erwartete Schutz-Weiterleitungen für  
nicht angemeldete Zugriffe auf geschützte Routen).  
Bekannte Messgrenzen (ausdrücklich):

- keine angemeldeten Sitzungen, keine Schreibpfade, keine Uploads;
- keine Messenger-/Market-Transaktionslast;
- keine Datenbank-Innenmetriken (Verbindungen, Sperren, langsame Abfragen)

während des Tests erhoben;

- Medienauslieferung (signierte URLs) nicht Teil des Lastprofils;
- Einzelmessung, keine Wiederholung über mehrere Tage.

## 12. Geschäftsmodell (vorhandener Produktstand)

Bereits vorhandene Business-Produkte (keine Umsatzprognose, reine Bestandsdokumentation):

| Y-Dude Business     | 14,90 € | 149 € |
|---------------------|---------|-------|
| Y-Dude Business Pro | 39 €    | 390 € |

Weitere angelegte Ertragsmechaniken:

- **Market-Gebührenmodell** (market\_fee\_settings, serverseitig geschützt),

Zahlungsabwicklung über Stripe inkl. Webhook-Idempotenz.

- **Werbung:** Ad-Adapter-Architektur mit TCF-v2.2-Gating; AdSense-Publisher-ID

hinterlegt, Auslieferung **BEWUSST ZURÜCKGESTELLT**.

Der Registrierungs-UX-Release vom 2026-08-30 hat **keine** Änderung an Stripe, Preisen, Produkten oder Subscription-Logik vorgenommen: Es wurde ausschließlich ein primärer CTA „Als Privatperson registrieren“ und ein sekundärer Textlink „Für Unternehmen registrieren“ ergänzt, der auf den **bestehenden** /business-Flow verweist; Preistexte wurden bewusst nicht in die Registrierung übernommen.

## 13. Marktpotenzial

Sachliche Einordnung ohne Prognosezahlen:

- Adressiertes Feld: sprach- und dialektbezogene Social-Interaktion; der SlangTag ist ein eigenständiges Format, das sich von reinen Kurzvideo- oder Text-Feeds abgrenzt.
- Mehrsprachige Auslieferung (DE/EN/EL) mit geobasierter Vorauswahl ist bereits produktiv – Voraussetzung für Mehrmarkt-Betrieb.
- Zwei Nachfrageseiten sind technisch angelegt: Endnutzer (kostenfrei, werbe- bzw. marktplatzfinanziert) und Unternehmen/Creator (Abo, Business-Tags, Market).
- Nutzungs- und Umsatzzahlen des Livebetriebs sind in dieser Analyse **NICHT MESSBAR** und werden bewusst nicht geschätzt.



## 14. Entwicklungsrisiken (offen)

|                                                          |                                |                                                                                                                                                                                                                                                                                                                                                   |
|----------------------------------------------------------|--------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| public/* ohne langlebiges CDN-Caching                    | BEWUSST ZURÜCKGESTELLT         | statische Dateien (robots.txt, ads.txt, lms.txt, Manifest) werden ohne bzw. mit no-cache ausgeliefert; Ursache liegt in der Static-Assets-Architektur der Edge-Auslieferung, in der nur gehashte /assets/* unveränderlich markiert werden. Wirkung: zusätzliche Origin-Anfragen für wenige kleine Dateien, kein Sicherheits- oder Funktionsrisiko |
| Angemeldete Lastpfade ungemessen                         | NICHT MESSBAR                  | Feed-Personalisierung, Messenger, Market-Schreiben, Uploads                                                                                                                                                                                                                                                                                       |
| DB-Observability während Last                            | NICHT MESSBAR                  | keine Innenmetriken im Lasttest erhoben                                                                                                                                                                                                                                                                                                           |
| Medienlast                                               | NICHT MESSBAR                  | signierte, private Auslieferung nicht im Lastprofil                                                                                                                                                                                                                                                                                               |
| Staging und Production teilen Datenbank/Auth/Storage     | NICHT IMPLEMENTIERT (Trennung) | Remix mit aktiven Payments nicht unterstützt; DB-Integrationstests deshalb strikt lesend                                                                                                                                                                                                                                                          |
| Security-Linter-Baseline 57 Findings                     | akzeptiert                     | dokumentiert, keine Kategorie A/D im Audit                                                                                                                                                                                                                                                                                                        |
| comments für anon lesbar (nur zu öffentlichen Beiträgen) | akzeptiert (Kategorie C)       | Angriffsflächenreduktion möglich, kein Datenleck                                                                                                                                                                                                                                                                                                  |
| Einzelbetreiber-/Bus-Faktor                              | organisatorisch                | Runbooks vorhanden, Personalrisiko bleibt                                                                                                                                                                                                                                                                                                         |

## 15. Bereits gelöste technische Risiken

|                                                 |                                             |                                                 |
|-------------------------------------------------|---------------------------------------------|-------------------------------------------------|
| Ungekapselte auth.uid()-Auswertung pro Zeile    | Migrationen 1–4                             | 0 ungekapselte Policies                         |
| Ineffiziente/uneinheitliche has_role()-Aufrufe  | Migrationen 5–8                             | 71 gekapselt, 23 dokumentierte Ausnahmen        |
| Fehlende Indexe auf Hot-Paths                   | Migrationen 9–10                            | 323 → 325 Indexe, Delta exakt +2                |
| Wiederholtes SSR-Rendern öffentlicher Seiten    | Block B                                     | HIT-Raten 78,9 → 91,8 % unter Last              |
| Requestflut bei View-Zählung / Übersetzungen    | Blöcke C/D                                  | Batching mit Fallback                           |
| Refetch-Wellen bei Fokuswechsel/Navigation      | Block A                                     | React-Query-Defaults, Preload-Stale-Time        |
| Marker-Kopfzeile in Antworten mit Sitzung       | Nachbesserung Block B                       | Marker auf allen Pfaden entfernt                |
| „permission denied for function can_view_post“  | Ausführungsrechte gesetzt                   | für anon nicht mehr reproduzierbar              |
| Lange Beiträge ohne SlangTag nicht publizierbar | Titel-Fallback auf ≤ 40 Zeichen gekürzt     | docs/PRODUCTION_BUGFIX_LONG_POSTS_2026-08-30.md |
| Vollständige Medien-Neudownloads pro Tab        | geräteweite, kontogetrennte Signatur-Ablage | docs/MEDIEN_CDN_CACHE_2026-08-27.md             |
| Metadaten-Leaks über Realtime                   | scoped Kanäle                               | docs/REALTIME_SICHERHEIT_2026-08-27.md          |

## 16. Offene technische Aufgaben

1. **public/\* CDN-Caching** nachziehen (Cache-Regeln bzw. Auslieferung über gehashte Pfade) – bewusst zurückgestellt, nicht umgesetzt.
2. **Lasttest für angemeldete Pfade** inkl. Schreibvorgängen, Messenger und Market.

### 3. **DB-Observability unter Last** (Verbindungen, langsame Abfragen, Sperren)

in den Testlauf integrieren.

### 4. **Medienlastprofil** (signierte URLs, Varianten, Uploads) messen.

5. **Echte Umgebungstrennung** Staging/Production (blockiert durch aktive Payments beim Remix); solange Testebene strikt lesend halten.

### 6. **Kategorie-C-Finding** comments optional auf authenticated einschränken.

7. **AdSense-Live-Schaltung** inkl. Consent-Nachweis, falls wirtschaftlich gewünscht.

### 8. **Wiederholbare Lastmessung** als geplante Routine statt Einzelmessung.

## 17. Wirtschaftliche Verwertung

- Verwertungspfade sind technisch bereits implementiert: Abonnements (Stripe, zwei Produktstufen), Marktplatzgebühren, Werbung (deaktiviert).
- Die Plattform ist mehrsprachig ausliefernd und damit ohne Umbau in DE, EN und EL nutzbar.
- Der Code ist als geschlossene Eigenentwicklung strukturiert (486 Dateien / 101.730 Zeilen TS/TSX in `src/`), mit dokumentierter Open-Source-Bestandsaufnahme für Fremdkomponenten.
- Betriebsfähigkeit ist durch Runbooks, Alerting, Health-Dashboard und Freigabegate (`scripts/verify.sh`) belegt.
- Konkrete Umsatz-, Nutzer- oder Bewertungsprognosen werden in diesem Dokument bewusst **nicht** erstellt.

## 18. IBB-ProFIT-Einordnung

Diese Einordnung ist eine sachliche Selbsteinschätzung und **\*\*keine rechtliche oder förderrechtliche Aussage\*\***; über Förderfähigkeit und Bewilligung entscheidet ausschließlich der Fördermittelgeber.

| A Innovationsgrad                 | hoch für das SlangTag-Format und die serverseitige Sichtbarkeitssemantik; mittel bei Feed/Marktplatz als Gattung | Abschnitt 6    |
|-----------------------------------|------------------------------------------------------------------------------------------------------------------|----------------|
| B Technologische Eigenleistung    | hoch: Zugriffskontrolle, Cache-, Batch- und Moderationslogik selbst entwickelt                                   | Abschnitt 7    |
| C Software-/Systemarchitektur     | belastbar dokumentiert, klare Server-/Client-Grenzen, Edge-Modell                                                | Abschnitt 5    |
| D Skalierbarkeit                  | gemessen bis 366 RPS / 750 VUs ohne Fehler; angemeldete Pfade offen                                              | Abschnitt 9/11 |
| E IT-Sicherheit                   | mehrschichtig, auditiert, Gate ■ GRÜN                                                                            | Abschnitt 8    |
| F Datenschutz-/Zugriffskonzept    | RLS-first, private Medien, DSGVO-Werkzeuge, Audit-Log                                                            | Abschnitt 5/8  |
| G Technische Entwicklungsleistung | 10 Migrationen, 4 Performance-Blöcke, 516 automatisierte Tests                                                   | Abschnitt 4/20 |

| H Markt-/Produktpotenzial             | Format- und Mehrsprachigkeitsvorteil; Nutzungszahlen nicht messbar                                                      | Abschnitt 13   |
|---------------------------------------|-------------------------------------------------------------------------------------------------------------------------|----------------|
| I Geschäftsmodell                     | implementiert (Abo, Market, Werbung deaktiviert)                                                                        | Abschnitt 12   |
| J Entwicklungsstand                   | produktiv betriebene Plattform mit definierter Restliste                                                                | Abschnitt 4/16 |
| K Technische Risiken                  | offen dokumentiert, keine sicherheitskritische Kategorie                                                                | Abschnitt 14   |
| L Verbleibende Entwicklungsaufgaben   | acht konkrete Punkte                                                                                                    | Abschnitt 16   |
| M Wirtschaftliche Verwertbarkeit      | Mechanik vorhanden, Skalierung offen                                                                                    | Abschnitt 17   |
| N Nachhaltigkeit der Lösung           | Tests, Runbooks, Freigabegate, dokumentierte Baselines                                                                  | Abschnitt 20   |
| O Abgrenzung zu Standard-Webprojekten | deutlich: 285 Policies, Sicherheitsfunktionen, Edge-SSR-Cache mit Sicherheitsgate, Batch-Layer, 3D-Globe, KI-Moderation | Abschnitt 6/7  |

Für einen Antrag zu konkretisieren wären insbesondere: Arbeitspaket- und Zeitplanung der offenen Punkte aus Abschnitt 16, Personal- und Kostenansatz, Abgrenzung Eigenleistung/Fremdleistung in Stunden sowie belastbare Marktdaten (Nutzung, Zielgruppen, Wettbewerb).

## 19. Schlussbewertung

Der Production-Stand vom 2026-08-30 ist ein sicherheitsgehärtetes, unter Last gemessenes und automatisiert getestetes System. Die Entwicklungen der letzten zwei Tage haben die Zugriffskontrolle formal vereinheitlicht (0 ungekapselte `auth.uid()`-Policies), die Serverlast pro Nutzeraktion strukturell gesenkt (SSR-Cache, Batching, Query-Defaults) und die Belastbarkeit erstmals mit 94.720 Requests und 0 Serverfehlern belegt.

Offen bleiben bewusst benannte Punkte, insbesondere das zurückgestellte `public/*-CDN-Caching`, die fehlende Lastmessung angemeldeter Pfade und die fehlende echte Umgebungstrennung. Diese Punkte sind dokumentiert, priorisierbar und stellen keine Sicherheitslücken dar.

Status: ■ **IBB-ProFIT PRODUCTION ANALYSE ERSTELLT**

## 20. Technische Nachweise / Kennzahlen (mit Quelle)

| Policies (public)                            | 285                                | docs/PROD_FINAL_RELEASE_CHECKPOINT_2026-08-29.md |
|----------------------------------------------|------------------------------------|--------------------------------------------------|
| RLS-Tabellen                                 | 116                                | ebd.                                             |
| Indexe (public)                              | 325 (vorher 323)                   | ebd.                                             |
| Ungekapselte <code>auth.uid()</code>         | 0                                  | ebd.                                             |
| Gekapselte <code>has_role()</code>           | 71                                 | ebd.                                             |
| Bewusst unveränderte <code>has_role()</code> | 23                                 | ebd.                                             |
| Security-Linter-Baseline                     | 57 Findings / 4 Typen, keine neuen | ebd.                                             |

| RLS-Audit-Kategorien                         | posts B, slang_tags B, channel_categories B, comments C                                                            | docs/SECURITY_AUDIT_RLS_PUBLIC_POLICIES_2026-08-29.md                                                                       |
|----------------------------------------------|--------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------|
| Anon-Leseversuche                            | posts/slang_tags/profiles → 42501; connections/messages → []                                                       | ebd.                                                                                                                        |
| Unit-Tests                                   | 480 bestanden (21 Dateien), Laufzeit 12,69 s                                                                       | lokaler Lauf <code>bun run test</code> , 2026-08-30 12:54 UTC                                                               |
| DB-Integrationstests                         | 26 (2 Dateien), nur lesend                                                                                         | <code>bun run verify</code> , Release-Dokumente                                                                             |
| E2E-Tests                                    | 10 bestanden, 1 übersprungen                                                                                       | ebd.                                                                                                                        |
| Build                                        | <code>build</code> OK                                                                                              | Release-Dokumente 2026-08-29/30                                                                                             |
| Load-Test gesamt                             | 94.720 Requests, 0×5xx, 0×4xx, 1 Timeout                                                                           | docs/Y-DUDE_PRODUCTION_LOADTEST_750_USERS_2026-08-30.json                                                                   |
| Spitzendurchsatz                             | 366,38 RPS (750 VUs)                                                                                               | ebd.                                                                                                                        |
| Latenz 750 VUs                               | p50 32 ms, p95 45 ms, p99 114 ms                                                                                   | ebd.                                                                                                                        |
| SSR-HIT-Rate 750 VUs                         | 8.340/9.084 = 91,8 %                                                                                               | ebd.                                                                                                                        |
| /assets/* Cache-Kopfzeile                    | <code>public, max-age=31536000, immutable</code>                                                                   | Live-Abruf <a href="https://y-dude.com/assets/index-BkSPwAA.js">https://y-dude.com/assets/index-BkSPwAA.js</a> , 2026-08-30 |
| public/* Cache-Kopfzeile                     | <code>robots.txt/ads.txt/llms.txt</code> : keine <code>cache-control</code> ; Manifest: <code>no-cache</code>      | Live-Abrufe, 2026-08-30                                                                                                     |
| Öffentliche HTML-Antwort                     | <code>vary: Cookie, Authorization, x-ydude-cache: miss, cache-control: no-cache, must-revalidate, max-age=0</code> | Live-Abruf /agb, 2026-08-30                                                                                                 |
| HSTS                                         | <code>max-age=31536000; includeSubDomains</code>                                                                   | Live-Abruf, 2026-08-30                                                                                                      |
| Quellcode <code>src/</code>                  | 486 Dateien, 101.730 Zeilen TS/TSX                                                                                 | Repository-Zählung, 2026-08-30                                                                                              |
| Routen (Dateien in <code>src/routes</code> ) | 41 Einträge                                                                                                        | ebd.                                                                                                                        |
| Testdateien                                  | 34 (Unit/Integration/E2E, TS)                                                                                      | ebd.                                                                                                                        |
| Business-Produkte                            | 14,90 €/Monat · 149 €/Jahr; Pro 39 €/Monat · 390 €/Jahr                                                            | vorhandener Produktstand                                                                                                    |

## 21. Was hat sich gegenüber der letzten Analyse verändert?

Bezugspunkt: docs/IBB\_PROFIT\_TECHNISCHER\_AUSZUG\_2026-08-28.md.

Ausschließlich die Entwicklungen vom 2026-08-29 und 2026-08-30:

- RLS-/Security-Härtung abgeschlossen:** Migrationen 1–10 angewendet (InitPlan-Kapselung 1–4, `has_role`-Blöcke A–D in 5–8, Indexblöcke 9–10).  
Ergebnis: 285 Policies, 116 RLS-Tabellen, 325 Indexe (+2), 0 ungekapselte `auth.uid()`-Policies, unveränderte Security-Linter-Baseline (57 Findings).
- Read-only-RLS-Audit** der als „public“ gemeldeten Policies mit Kategorisierung A–D und Gate-Ergebnis ■ GRÜN; `comments` als Kategorie C bewusst akzeptiert.
- Performance-Release Blöcke A–D** angewendet: React-Query-Defaults und 30-s-Preload-Stale-Time, SSR-Cache für öffentliche Beitragsseiten mit Marker-Gate, View-Batch (700 ms), Translation-Batch (120 ms / max. 20 IDs); zusätzlich Sicherheitsnachbesserung beim internen Cache-Marker.
- Erster Production-Load-Test bis 750 VUs:** 94.720 Requests, 0 Serverfehler,

0 HTTP-4xx, 1 Timeout, p95 45 ms bei 750 VUs, SSR-HIT bis 91,8 %.

5. **CDN-Analyse:** /assets/\* unveränderliches Caching bestätigt, public/\* bewusst zurückgestellt (Ursache: Static-Assets-Architektur der Edge-Auslieferung), private Medien weiterhin ausschließlich signiert.

6. **Produktionsfehlerbehebung:** lange Beiträge ohne SlangTag publizierbar (Titel-Fallback  $\leq 40$  Zeichen); can\_view\_post-Fehler für anon nicht mehr reproduzierbar.

7. **Registrierungs-UX:** primärer CTA „Als Privatperson registrieren“, sekundärer Einstieg „Für Unternehmen registrieren“ auf den bestehenden /business-Flow – ohne neue Business-Logik, ohne Preistexte, ohne Stripe-/Subscription-Änderung. Ein Launchpad-Paket wurde zuvor wegen Baseline-Mismatch abgelehnt (Scope-Gate).